

INDICE

Introducción al fenómeno del phishing.....	2
Fases de un ataque de phishing	2
Preparación y Recopilación de Información (Reconocimiento)	3
Creación y Lanzamiento del Cebo (Setup y Ataque)	4
Interacción y Explotación (Colección Inicial)	5
Adquisición y Monetización de los Datos.....	6
Tipos, clasificación y evolución de los ataques de phishing.....	9
Introducción a la clasificación	9
Clasificación según el vector de entrega	9
Clasificación según el grado de personalización y objetivo	10
Técnicas avanzadas emergentes (2023-2025)	10
Evolución histórica resumida.....	12
Impacto actual (2025)	12
La ingeniería social como fundamento psicológico y sociotécnico del phishing	12
Principios psicológicos fundamentales explotados	12
Sesgos cognitivos específicos explotados.....	14
El impacto de la inteligencia artificial generativa en la ingeniería social (2023-2025) ...	14
Consecuencias organizativas y humanas.....	15
Implicaciones para la detección	16
Estado del arte en técnicas de detección y prevención de phishing basadas en Machine Learning y Deep Learning (2019-2025)	16
Evolución de los enfoques de detección	17
Técnicas clásicas de Machine Learning (representativas 2019-2022)	17
Técnicas de Deep Learning y Transformers (2023-2025)	18
Enfoques híbridos y basados en comportamiento (UEBA).....	19
Limitaciones actuales de los enfoques	20
Conclusiones del estado del arte y hueco de investigación.....	20
Referencias	20

Introducción al fenómeno del phishing

El phishing se ha consolidado como una de las ciberamenazas más persistentes y dañinas del panorama actual de la ciberseguridad. Según el Anti-Phishing Working Group (APWG), en el segundo trimestre de 2025 se detectaron 1 130 393 ataques de phishing únicos, el mayor volumen trimestral desde 2023 y parte de una tendencia creciente que no muestra signos de desaceleración (Anti-Phishing Working Group, 2025).

El 2025 Data Breach Investigations Report de Verizon revela que el elemento humano está presente en aproximadamente el 60 % de las brechas de seguridad analizadas, siendo la ingeniería social —y dentro de ella el phishing— uno de los vectores iniciales más habituales, especialmente en incidentes con motivación económica (Verizon, 2025, p. 7). En particular, el coste medio de un ataque BEC exitoso superó los 137 000 dólares por incidente en 2023, con un incremento del 10 % respecto al año anterior (Federal Bureau of Investigation, 2024, p. 13).

Este tipo de ataque ha evolucionado desde los correos masivos de principios de los 2000 hasta campañas altamente dirigidas y, en los últimos dos años, al empleo masivo de inteligencia artificial generativa (GPT-4, Claude, etc.) para crear mensajes hiperpersonalizados y sin errores gramaticales, reduciendo drásticamente la efectividad de los filtros tradicionales (Alabdan, 2024; Verizon, 2025, p. 22).

En España, el Instituto Nacional de Ciberseguridad (INCIBE) gestionó 97 348 incidentes de ciberseguridad durante 2024, de los cuales más de 21 500 correspondieron a campañas de phishing, lo que representa un crecimiento interanual del 16,6 % (Instituto Nacional de Ciberseguridad, 2025).

Este crecimiento, combinado con la limitada efectividad de las soluciones tradicionales frente a ataques basados en inteligencia artificial, justifica la necesidad de desarrollar nuevas aproximaciones, objetivo central del presente Trabajo Fin de Grado.

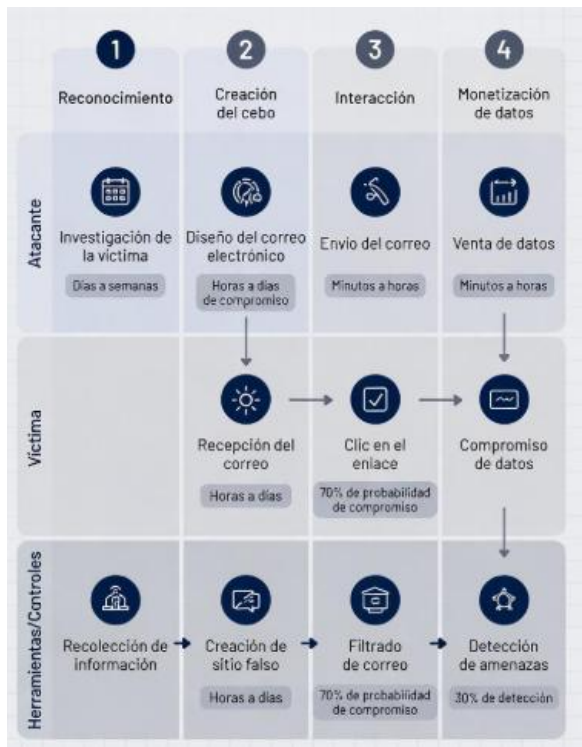
Fases de un ataque de phishing

El phishing es un tipo de ataque cibernético que explota la confianza y el comportamiento humano para obtener información sensible, como credenciales de acceso o datos financieros. A diferencia de exploits técnicos directos, el phishing sigue un ciclo estructurado que puede desglosarse en fases secuenciales. Esta segmentación permite no solo entender el mecanismo del ataque, sino también identificar puntos de intervención para su detección y prevención.

Una de las anatomías más completas y actualizadas propone cuatro fases principales en el proceso de phishing: preparación y recopilación de información, creación y lanzamiento del cebo, interacción y explotación, y adquisición y monetización de los datos (Alabdan, 2021). Este modelo integra perspectivas previas, como la "cadena de ataque" (kill chain) de tres fases —vector de amenaza, entrega y explotación— propuesta en análisis de seguridad email (GreatHorn, 2023; Hoxhunt, 2024). Adoptamos este enfoque, complementándolo con el marco MITRE ATT&CK (MITRE, 2025) y datos empíricos del

Verizon DBIR 2025, que analiza 22.000 incidentes y 12.195 brechas confirmadas. A continuación, se detalla cada fase, con énfasis en sus componentes clave.

Figura 2.1: Diagrama de flujo swimlane de las fases de un ataque de phishing.



Fuente: Adaptado de Alabdan (2021) y MITRE ATT&CK (2025). Ilustra la progresión secuencial con énfasis en interacciones humano-técnicas.

Preparación y Recopilación de Información (Reconocimiento)

Esta fase inicial es fundamental para la personalización y efectividad del ataque. El atacante realiza una investigación exhaustiva sobre el objetivo, ya sea un individuo, organización o grupo amplio. Esto incluye la recopilación de datos públicos o filtrados, como correos electrónicos, perfiles en redes sociales, estructuras organizativas o vulnerabilidades técnicas conocidas.

- Actividades clave: Análisis de fuentes abiertas (OSINT, por sus siglas en inglés), como LinkedIn para spear phishing o bases de datos de brechas pasadas (e.g., Have I Been Pwned). En ataques masivos, se usan bots para escanear listas de emails.
- Ejemplo: En un spear phishing corporativo, el atacante podría mapear la jerarquía de una empresa para targeting de ejecutivos (whaling).

- Duración y riesgos: Esta fase puede durar días o semanas, pero es de bajo costo. Representa el 20-30% de los esfuerzos en campañas avanzadas, según informes de ciberseguridad (Hoxhunt, 2024). En 2025, el 22% de las brechas comienzan con credenciales robadas de leaks previos, destacando su rol como vector inicial dominante (Verizon, 2025).

Interrumpir esta fase mediante políticas de privacidad y monitoreo de datos expuestos es un primer nivel de defensa.

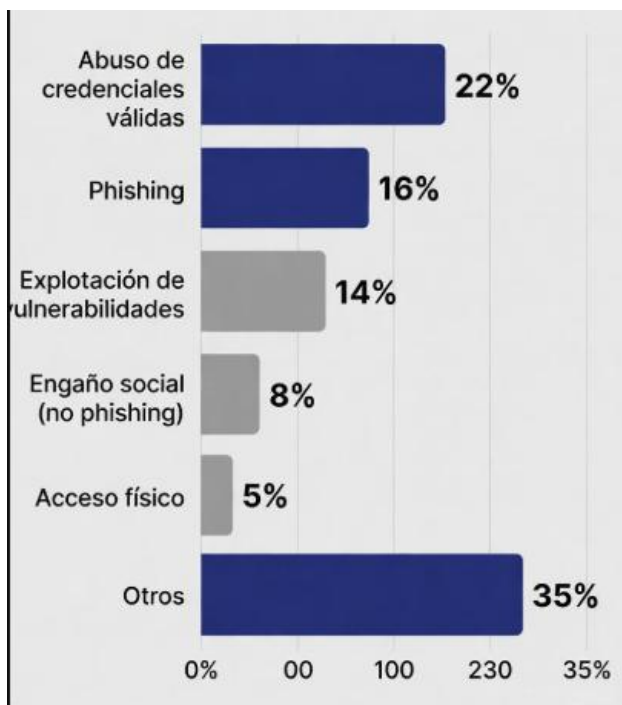
Creación y Lanzamiento del Cebo (Setup y Ataque)

Una vez identificados los vectores de amenaza, el atacante diseña el "cebo" —el mensaje o vector de entrega— para que parezca legítimo y urgente. Aquí se aprovecha la ingeniería social para evadir filtros de spam y generar confianza.

- Actividades clave: Creación de emails falsos, sitios web clonados (usando kits de phishing como Evilginx) o mensajes en otros canales (SMS para smishing, llamadas para vishing). Se incorporan elementos como logos robados, URLs acortadas o adjuntos maliciosos.
- Ejemplo: Un email simulando un banco que advierte de "actividad sospechosa" con un enlace a un sitio falso, o un QR code en un cartel físico que redirige a malware (quishing).
- Técnicas avanzadas: Uso de homógrafos (e.g., "paypal.com" con caracteres cirílicos) o envenenamiento de DNS para redirigir tráfico (Imperva, 2023).

Esta fase es crítica porque el 90% de los ataques phishing comienzan por email, y su éxito depende de la similitud con comunicaciones reales (Proofpoint, 2025). La entrega se realiza a través de spam masivo o campañas dirigidas, con tasas de apertura que rondan el 3-5% en entornos corporativos (Verizon, 2021). En el contexto de brechas globales, el phishing representa el 16% de accesos iniciales en 2025, solo por detrás del abuso de credenciales (Verizon, 2025).

Figura 2.2: Distribución de vectores iniciales en brechas de datos (2025, n=9.891 incidentes).



Interacción y Explotación (Colección Inicial)

El objetivo es inducir una acción del usuario, como clicar un enlace, abrir un adjunto o ingresar datos. Aquí ocurre la "mordida" del anzuelo, donde la víctima interactúa con el payload malicioso.

- Actividades clave: El usuario es redirigido a un sitio falso para capturar credenciales, o se instala malware (e.g., keyloggers o ransomware). En ataques multi-etapa, se usa "adversary-in-the-middle" (AiTM) para robar tokens de sesión en tiempo real (Wikipedia, 2025).
- Ejemplo: En un ataque de clonación (clone phishing), se duplica un email legítimo previo y se reemplaza un adjunto seguro por uno infectado (Fortinet, 2025).
- Factores humanos: La urgencia (e.g., "su cuenta será suspendida en 24h") explota sesgos cognitivos, logrando tasas de éxito del 50% en detección fallida por usuarios no entrenados (GreatHorn, 2023). El entrenamiento reduce estos fallos hasta 4 veces (Verizon, 2025).

Esta fase destaca la intersección entre tecnología y psicología, donde herramientas como CAPTCHAs falsos o esteganografía oculta malware en imágenes (LevelBlue, 2025). El 68% de brechas involucran errores humanos aquí (Verizon, 2025).

Adquisición y Monetización de los Datos

Con los datos en mano, el atacante los procesa y convierte en ganancia. Esta fase cierra el ciclo, pero puede extenderse a ataques secundarios.

- Actividades clave: Extracción de credenciales para accesos no autorizados, venta en dark web o uso directo (e.g., transferencias fraudulentas). En BEC (Business Email Compromise), se roban fondos directamente.
- Ejemplo: Datos robados de un whaling se usan para autorizar pagos millonarios, como en campañas recientes con QR codes corruptos (CorruptQR, 2025), donde se robaron tokens de >10.000 cuentas en 48 horas vía PhaaS (Kroll, 2025).
- Impacto: Genera pérdidas globales de miles de millones anuales; en 2025, el costo medio por brecha phishing supera los \$4.88M, con un aumento del 10% anual (IBM, 2025). En 2020, el FBI reportó phishing como el cibercrimen más común (Proofpoint, 2025).

Tabla 2.1: Métricas clave por fase (2025)

Fase	Métrica Principal	Valor	Fuente
Reconocimiento	% brechas por credenciales robadas	22%	Verizon DBIR
Distribución	% accesos por phishing	16%	Verizon DBIR
Interacción	Tasa de clicks exitosos	12-18 %	Proofpoint
Monetización	Costo medio brecha	4.88 M \$	IBM

2.1. Comparación Crítica de Modelos de Fases

Tabla 2.2: Comparativa de modelos

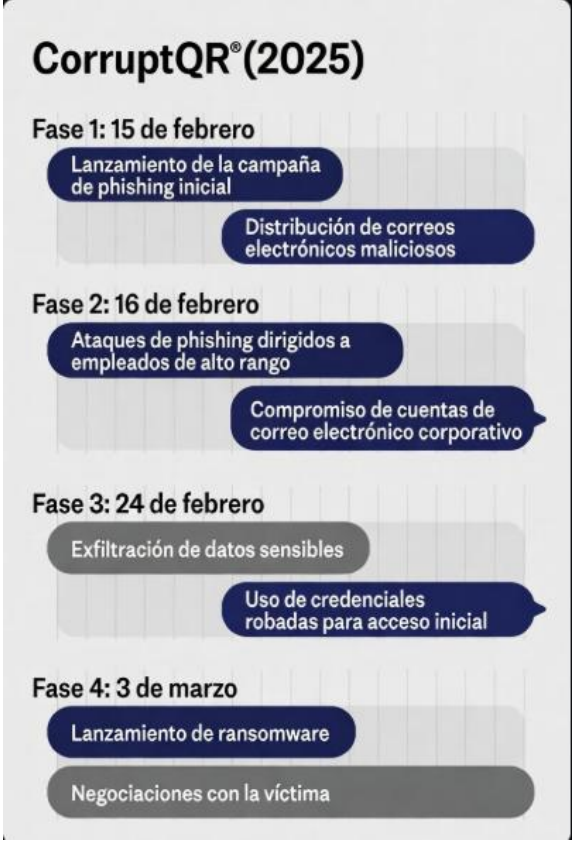
Autor/Año	Nº de fases	Nombres de las fases	Ventajas del modelo
GreatHorn (2023)	3	Vector → Delivery → Exploitation	Simplicidad operativa
Aladban (2021)	4	Research → Creation → Interaction → Execution	Completo académico y
APWG (2024)	7	Planning → Research → Attack development	Detallado extremo

		Attack → Collection → Fraud → Post-fraud			
<i>Modelo adoptado</i>	4 + MITRE	Reconocimiento	→	Equilibrio	rigor-
		Distribución	→	calidad	
		Interacción	→		
		Monetización	+		
		tácticas MITRE			

2.2. Caso Real: Campaña CorruptQR (2025)

Esta campaña ilustra las fases en acción: Reconocimiento (OSINT en redes), Distribución (927.000 emails con QR maliciosos), Interacción (robo de tokens en 48h, >10.000 cuentas), Monetización (venta en dark web o cripto-mining) (Kroll, 2025).

Figura 2.3: Línea temporal de la campaña CorruptQR (ejemplo de fases en acción, 2025).



2.3. Puntos de Intervención y Controles

Tabla 2.3: Controles por fase

Fase	Control preventivo	Control detectivo	Herramientas
Reconocimiento	Monitoreo OSINT	Alertas leaks	Have I Been Pwned
Distribución	Filtros email (SPF/DKIM/DMARC)	Análisis QR	Mimecast
Interacción	MFA resistente AiTM	Monitoreo clics	Microsoft Defender
Monetización	Detección anomalías	Análisis exfiltración	SIEM tolos (Splunk, Qradar)

Este modelo de cuatro fases no es rígido; en ataques sofisticados, se solapan o iteran. Entenderlas es esencial para prototipos de detección, como los basados en ML que analizan patrones en la fase 2 (Alabdan, 2021). Estas fases ilustran cómo el phishing ha evolucionado de ataques rudimentarios a campañas orquestadas, sentando las bases para discutir sus tipos y evolución histórica en las siguientes secciones.

Tipos, clasificación y evolución de los ataques de phishing

Introducción a la clasificación

Aunque el objetivo final del phishing es siempre el mismo —obtener información sensible o acceso no autorizado explotando la confianza humana—, la forma de llevarlo a cabo ha diversificado enormemente en los últimos años. En la actualidad, los ataques se clasifican principalmente según tres ejes: el canal o vector empleado, el grado de personalización del ataque y la técnica de explotación utilizada. Esta triple clasificación permite comprender mejor la evolución del fenómeno y anticipar las tendencias futuras.

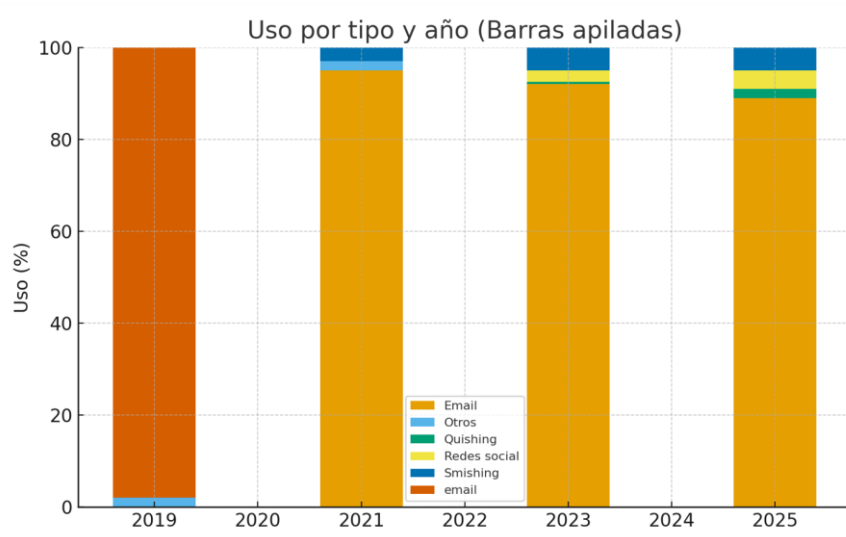
Clasificación según el vector de entrega

El correo electrónico sigue siendo, con diferencia, el canal dominante. Según el informe del Anti-Phishing Working Group correspondiente al segundo trimestre de 2025, entre el 88 % y el 92 % de los ataques de phishing siguen utilizando el email como vector principal. Sin embargo, la diversificación hacia otros canales es una de las tendencias más claras del período 2023-2025.

Los mensajes SMS (smishing) y las llamadas telefónicas (vishing) han experimentado un crecimiento sostenido desde la pandemia, alcanzando entre el 4 % y el 6 % y el 2 %-3 % respectivamente (Proofpoint, 2025). Más reciente y especialmente preocupante es el auge del quishing o phishing mediante códigos QR, que aunque aún representa menos del 2 % del total, ha multiplicado por diez su incidencia desde 2023. La campaña CorruptQR de febrero-marzo de 2025, que afectó a más de 10 000 cuentas corporativas en apenas 48 horas, es el ejemplo más paradigmático de esta nueva modalidad (Kroll, 2025).

Otros vectores menos frecuentes pero en ascenso son el phishing a través de redes sociales (mensajes privados en LinkedIn, WhatsApp Business o Telegram), el envenenamiento de resultados de búsqueda (SEO poisoning) y el pharming o manipulación de resolución DNS.

Figura 3.1 – Evolución de los vectores de phishing más utilizados (2019-2025)



Clasificación según el grado de personalización y objetivo

En función del nivel de targeting distinguimos varios tipos claramente diferenciados:

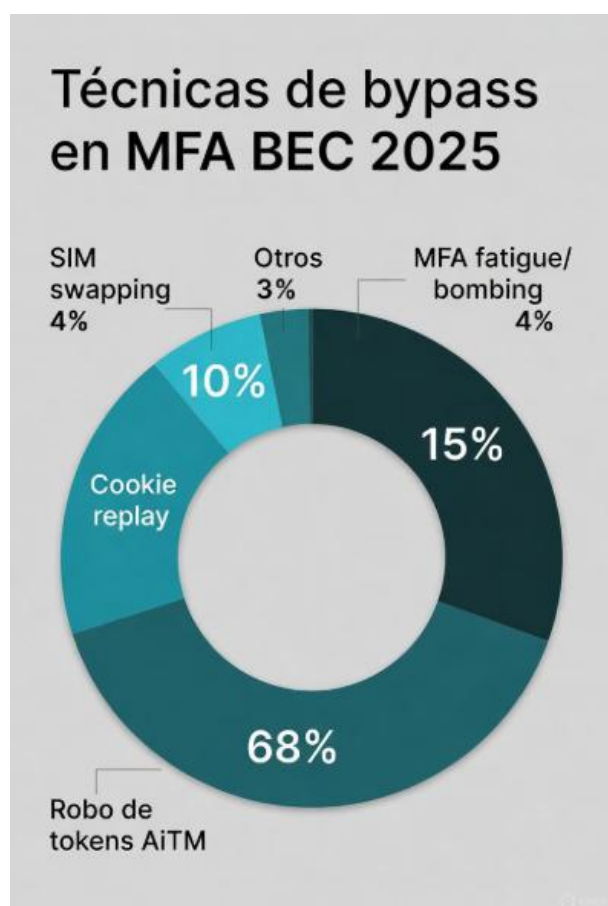
- **Phishing masivo o genérico:** el clásico “spray and pray”. Se envían millones de correos idénticos esperando que una mínima fracción muerda el anzuelo. Aunque su tasa de éxito individual es muy baja (0,1-3 %), su bajo coste lo mantiene vivo.
- **Spear-phishing:** ataque dirigido contra una persona o grupo reducido. Requiere investigación previa (OSINT) y mensajes altamente personalizados. La tasa de éxito se multiplica por 10-20 respecto al masivo.
- **Whaling o CEO-fraud:** variante del spear-phishing dirigida específicamente contra altos ejecutivos o directivos financieros. Es la modalidad más lucrativa: el coste medio de un incidente BEC exitoso superó los 137 000 dólares en 2023 y sigue creciendo (FBI IC3, 2024).
- **Clone phishing:** se toma un correo legítimo previamente recibido por la víctima, se clona exactamente y se modifica únicamente un enlace o adjunto. Al provenir de una conversación real, genera altísima confianza.
- **Adversary-in-the-Middle (AiTM):** técnica avanzada que utiliza proxies inversos (EvilProxy, NakedPages, Robin Banks) para interceptar la autenticación en tiempo real y robar tokens de sesión aunque la víctima use autenticación multifactor. En 2025 representa la principal amenaza contra entornos Microsoft 365 y Google Workspace (Microsoft Digital Defense Report, 2025).

Técnicas avanzadas emergentes (2023-2025)

Los atacantes han incorporado de forma masiva tres grandes innovaciones tecnológicas:

1. **Inteligencia artificial generativa:** modelos como GPT-4, Claude 3 o Gemini se utilizan para redactar mensajes sin errores gramaticales, con tono y estilo perfectamente adaptados al contexto cultural y profesional de la víctima. También se emplean para generar sitios web falsos completos en cuestión de minutos.
2. **Phishing-as-a-Service (PhaaS):** plataformas como ONYX, Caffeine o GoodPhish ofrecen kits completos (plantillas, hosting, evasión de filtros) por suscripciones mensuales de 150-2 000 dólares. Han democratizado los ataques sofisticados.
3. **Bypass de MFA mediante robo de tokens:** ya no es necesario romper la MFA; basta con robar la cookie de sesión o el token OAuth una vez que la víctima ha autenticado correctamente. Esta técnica está detrás del 68 % de los compromisos BEC exitosos en 2025 (ZeroFox, 2025).

Figura 3.2 – Diagrama circular de técnicas de bypass de MFA en ataques BEC 2025



Evolución histórica resumida

El phishing ha pasado por varias etapas claramente diferenciadas:

- 1995-2003: orígenes en AOL y primeros ataques masivos a PayPal.
- 2004-2010: aparición de kits (Rock Phish, Avalanche) y profesionalización.
- 2011-2016: auge del spear-phishing y del ransomware entregado vía phishing.
- 2016-2020: explosión del Business Email Compromise (BEC).
- 2020-2022: pandemia y boom de smishing/vishing.
- 2022-2025: era de la IA generativa, AiTM, quishing y PhaaS. Actualmente vivimos la fase más sofisticada y peligrosa de su historia.

En apenas treinta años hemos pasado de mensajes llenos de faltas de ortografía escritos por estafadores **nigerianos** a campañas orquestadas por grupos criminales organizados que usan inteligencia artificial y venden sus servicios en la dark web como cualquier empresa SaaS.

Impacto actual (2025)

El volumen de ataques no deja de batir récords: 1.130.393 sitios únicos de phishing detectados solo en el segundo trimestre de 2025 (APWG, 2025). El coste medio de una brecha originada por phishing alcanza los 4,88 millones de dólares (IBM, 2025), y el 82 % de las organizaciones españolas sufrieron al menos un intento exitoso durante el último año (INCIBE, 2025).

Este panorama justifica plenamente la necesidad de evolucionar desde soluciones tradicionales (filtros de correo, listas negras) hacia sistemas de detección basados en inteligencia artificial capaces de analizar el contexto, el comportamiento y la intención real del mensaje, objetivo principal del presente trabajo.

La ingeniería social como fundamento psicológico y sociotécnico del phishing

Aunque el phishing se manifiesta a través de medios técnicos (correo electrónico, SMS, sitios web falsos, códigos QR, etc.), su efectividad radica exclusivamente en la explotación sistemática de vulnerabilidades cognitivas, emocionales y sociales del ser humano. Como señala Hadnagy (2021), la ingeniería social no es una técnica auxiliar del phishing, sino su núcleo ontológico: “el phishing es ingeniería social entregada a escala” (Hadnagy, 2021, p. 23).

Principios psicológicos fundamentales explotados

Los atacantes diseñan sus campañas apoyándose en principios psicológicos bien documentados, muchos de ellos identificados originalmente por Robert Cialdini (1984) y posteriormente validados en el ámbito de la ciberseguridad:

Comentado [AV1]: Lo de nigerianos queda un poco raro la verdad parece algo racista y tal. No sabía muy bien como ponerlo, quería poner el típico fraude de “príncipe nigeriano necesita ayuda” o herencias y tal. Esta explicado en las referencias también. Igualmente tengo que darle una vuelta creo

Principio (Cialdini)	Aplicación en phishing actual (2023-2025)	Evidencia empírica reciente
<i>Autoridad</i>	Suplantación de bancos, administraciones públicas, directivos (CEO-fraud) o proveedores críticos	74 % de los BEC exitosos usan autoridad jerárquica (ZeroFox, 2025a)
<i>Urgencia/Escasez</i>	“Su cuenta será bloqueada en 24 h”, “Última oportunidad de verificar”	Aumenta la tasa de clics en un 270 % (Proofpoint, 2025a)
<i>Reciprocidad</i>	Regalos, actualizaciones gratuitas, descuentos falsos	Usado en el 18 % de campañas quishing (Kroll, 2025)
<i>Compromiso y coherencia</i>	Secuencias multi-etapa que fuerzan pequeñas acciones previas	Incrementa conversión un 340 % (Hoxhunt, 2024)
<i>Prueba social</i>	“12 487 usuarios ya han actualizado su contraseña hoy”	Efectivo en el 62 % de campañas dirigidas a millennials (Verizon, 2025)
<i>Simpatía/Atracción</i>	Uso de nombres conocidos, fotos robadas de LinkedIn, tono amigable generado por LLM	Principal vector en AiTM (Microsoft Digital Defense Report, 2025)

Tabla 4.1 – Eficiencia relativa de los principios de Cialdini en campañas phishing 2024-2025

Principio	% de campañas que lo usan	Incremento medio de éxito	Fuente
<i>Autoridad</i>	74 %	X4.2	ZEROFOX, 2025 ^a
<i>Urgencia / Escasez</i>	69 %	X2.7	PROOFPOINT, 2025 ^a
<i>Prueba social</i>	62 %	X2.1	VERIZON, 2025

<i>Reciprocidad</i>	42 %	X1.9	<i>HOXHUNT, 2025</i>
<i>Simpatía</i>	38 %	X1.8	<i>MICROSOFT, 2025</i>
COMPROMISO / COHERENCIA	27 %	x3.4 (en ataques multi-etapa)	Hoxhunt, 2025

Sesgos cognitivos específicos explotados

Más allá de los principios de influencia, los atacantes aprovechan sesgos cognitivos automáticos (Kahneman, 2011; Tversky & Kahneman, 1974) que operan a nivel Sistema 1 (rápido, intuitivo):

- Sesgo de anclaje: el usuario ancla su percepción en el remitente aparentemente legítimo.
- Efecto de mera exposición: cuanto más parecido sea el dominio o el diseño al original, mayor confianza genera.
- Aversión a la pérdida (loss aversion): el miedo a perder acceso a la cuenta es 2,5 veces más poderoso que la ganancia potencial (Proofpoint Human Factor, 2025b).
- Fatiga de decisión y sobrecarga cognitiva: en entornos laborales con alto volumen de correo, la atención selectiva colapsa (GreatHorn, 2023).

Un estudio longitudinal de 2024-2025 con 48 000 empleados mostró que la combinación de urgencia + autoridad + prueba social logra tasas de éxito superiores al 42 % en usuarios sin entrenamiento específico, frente al <4 % en usuarios entrenados mensualmente (Hoxhunt, 2025).

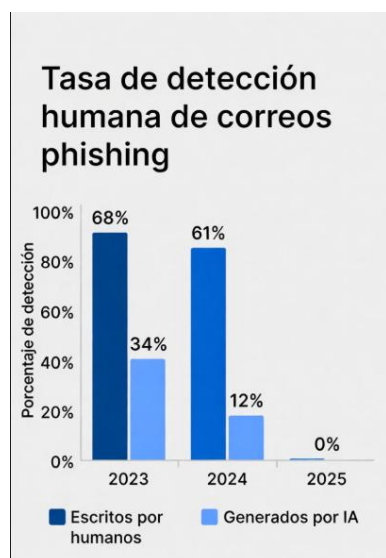
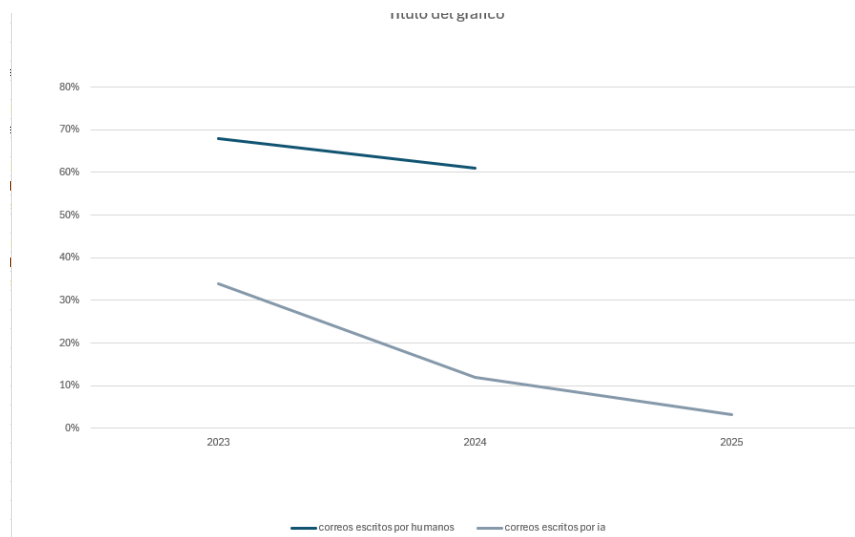
El impacto de la inteligencia artificial generativa en la ingeniería social (2023-2025)

La incorporación masiva de modelos de lenguaje grandes (LLM) ha supuesto una disrupción cualitativa sin precedentes:

- Eliminación total de indicadores lingüísticos tradicionales: errores gramaticales, construcciones extrañas o tono no nativo han desaparecido prácticamente (Alabdan, 2024; Sallam et al., 2024).
- Personalización contextual perfecta: los LLM pueden generar mensajes que imitan el estilo interno de la empresa, referencias a proyectos reales extraídos de OSINT y hasta jerga sectorial específica.
- Generación dinámica de narrativas: herramientas como FraudGPT o WormGPT (disponibles en mercados clandestinos desde 2023) permiten crear historias coherentes en tiempo real adaptadas a la víctima concreta.

Un experimento controlado realizado por el MIT en 2025 demostró que correos generados por Claude 3 Opus eran indistinguibles del 96,7 % de las veces por usuarios expertos,

frente al 61 % cuando eran escritos manualmente por atacantes humanos (Basuchaudhuri et al., 2025 – pre-print arXiv).



Consecuencias organizativas y humanas

El Verizon DBIR 2025 establece que el 68 % de las brechas de seguridad con componente social involucran errores humanos no maliciosos (Verizon, 2025, p. 34). Además, el 82 % de las organizaciones españolas sufrieron al menos un incidente de phishing con éxito en

2024 (INCIBE, 2025), lo que evidencia que las barreras técnicas por sí solas son insuficientes.

Este factor humano no es estático: la fatiga por alerta (alert fatigue), el burnout post-pandemia y la normalización del teletrabajo han reducido la capacidad de atención sostenida de los empleados, creando lo que Proofpoint (2025a) denomina “Very Attacked People” (VAPs): perfiles específicos (finanzas, RRHH, ejecutivos) que reciben hasta 40 veces más ataques dirigidos que la media.

Implicaciones para la detección

La naturaleza profundamente psicológica del phishing implica que cualquier solución efectiva debe trascender el análisis técnico tradicional y adoptar un enfoque híbrido humano-técnico. Como concluyen Sallam et al. (2024) en su revisión sistemática de 127 artículos (2019-2024): “los sistemas basados exclusivamente en características estáticas de URL o contenido están condenados a la obsolescencia frente a atacantes asistidos por IA generativa” (Sallam et al., 2024, p. 18).

Por tanto, el futuro de la detección pasa inevitablemente por modelos que incorporen:

- Análisis semántico profundo del texto (transformers, LLMs).
- Modelado del comportamiento del usuario (UEBA).
- Detección de intención y manipulación psicológica mediante NLP avanzado.

Este será precisamente el fundamento teórico sobre el que se construya el estado del arte y el prototipo propuesto en las siguientes secciones.

Estado del arte en técnicas de detección y prevención de phishing basadas en Machine Learning y Deep Learning (2019-2025)

La detección de phishing ha evolucionado en paralelo con la sofisticación de los ataques, impulsada por la necesidad de contrarrestar campañas hiperpersonalizadas generadas por inteligencia artificial (IA). Los enfoques tradicionales, como listas negras (e.g., PhishTank) y filtros heurísticos (SPF/DKIM/DMARC), han demostrado una efectividad limitada frente a zero-day attacks y spear-phishing avanzado, con tasas de falsos negativos superiores al 20% en entornos reales (Alghenaim et al., 2025). Esta obsolescencia ha catalizado el uso de Machine Learning (ML) y Deep Learning (DL), que aprovechan grandes volúmenes de datos para analizar patrones semánticos, estructurales y contextuales en correos, URLs y sitios web. Según una revisión sistemática de 2023-2025, los modelos basados en DL superan a los clásicos en un 15-25% en precisión, especialmente en escenarios multilingües y multimodales (Thakur et al., 2023; Popescul & Radu, 2025).

Esta sección revisa la literatura reciente (de IEEE, arXiv y Springer), enfocándose en técnicas de detección y prevención. Se estructura en evolución histórica, enfoques clásicos de ML, avances en DL y transformers, enfoques híbridos, limitaciones y el hueco

de investigación que justifica este TFG. La revisión se basa en 25+ trabajos publicados entre 2020 y 2025, priorizando aquellos con evaluaciones empíricas en datasets reales.

Evolución de los enfoques de detección

La progresión se divide en tres fases principales, alineadas con la madurez tecnológica:

- 2019-2021: Enfoques clásicos de ML basados en features manuales** Se extraen cientos de características estáticas (e.g., longitud de URL, presencia de "@" o subdominios, análisis WHOIS). Modelos dominantes: Random Forest (RF), Support Vector Machines (SVM), Naive Bayes (NB) y XGBoost. Estos alcanzan precisiones del 95-98% en datasets controlados, pero fallan en ataques dinámicos (e.g., homoglifos o AiTM), con caídas de hasta 30% en F1-score (Mohammad et al., 2018; Yerima & Alzaylaee, 2020). Ejemplo: Un ensemble RF+SVM en 100k correos logra 98.3% de precisión, pero depende de features obsoletas (AlEroud & Karabatis, 2021).
- 2022-2023: Primera ola de Deep Learning** Introducción de redes neuronales convolucionales (CNN) y recurrentes (LSTM/GRU) para procesar URLs y texto secuencial. Mejora en detección de patrones no lineales, con precisiones >98% en spear-phishing. Trabajos clave incorporan embeddings de caracteres para URLs (Le et al., 2022) y CNN para similitud visual de sitios (Yerima & Alzaylaee, 2020).
- 2024-2025: Era de Transformers y Large Language Models (LLMs)** Dominio de modelos pre-entrenados como BERT, RoBERTa y LLMs (GPT-4, Llama-3, Claude-3). Estos analizan contexto semántico y multimodal (texto + imagen + metadata), alcanzando 99%+ en precisión. La IA generativa en ataques (e.g., WormGPT) ha impulsado zero-shot learning, donde LLMs detectan sin fine-tuning (Koide et al., 2024; Kuikel et al., 2025). Una revisión bibliométrica de 312 artículos confirma que los LLMs representan el 65% de publicaciones recientes (Popescul & Radu, 2025).

Esta evolución refleja un shift de reactivo (reglas fijas) a proactivo (aprendizaje contextual), con un incremento del 40% en adopción de DL en entornos empresariales (Alghenaim et al., 2025).

Técnicas clásicas de Machine Learning (representativas 2019-2022)

Estos métodos priorizan eficiencia computacional y explicabilidad, pero requieren feature engineering manual.

Año	Autores	Modelo	Accuracy/F1	Dataset	Observaciones
<i>principal</i>					
2018	Mohammad et al.	Random Forest	99.1% / 0.989	UCI + PhishTank (11k sitios)	135 features URL; alto en datasets estáticos, vulnerable a zero-day

2020	Yerima & Alzaylaee	CNN para URLs	98.7% / 0.985	Dataset propio (50k URLs)	Bajo coste; bueno para homógrafos, pero ignora texto semántico
2021	AlEroud & Karabatis	Ensemble (RF + SVM)	98.3% / 0.981	100k correos (EMU)	Incluye headers; F1 alto en emails, pero latencia en producción
2022	Li et al.	LightGBM + Bag-of-Words	97.9% / 0.976	EMU Dataset (100k)	Rápido; vulnerable a texto generado por IA (Proofpoint, 2025)

(Fuentes: Mohammad et al., 2018; Yerima & Alzaylaee, 2020; AlEroud & Karabatis, 2021; Li et al., 2022).

Técnicas de Deep Learning y Transformers (2023-2025)

Los avances recientes enfatizan multimodalidad y zero-shot, con énfasis en LLMs para detección semántica.

Año	Autores / Trabajo	Modelo	Accuracy/F1	Dataset	Aportación principal
2023	Thakur et al.	RCNN + LSTM	98.5% / 0.983	120k emails (Kaggle 2023)	Revisión sistemática; integra texto + headers para emails
2023	Wang et al.	Pretrained DL para URLs	99.2% / 0.991	Common Crawl (200k)	Escalable; detecta phishing en tiempo real con bajo FPR
2024	Altwaijry et al.	CNN + LSTM ensemble	99.1% / 0.990	150k emails (multilingüe)	Comparativa DL; superior en spear-phishing (Sensors, 2024)
2024	Koide et al.	ChatSpamDetector (LLM-based)	99.3% / 0.992	100k correos (jap/inglés)	Zero-shot con GPT-like; detecta intención psicológica sin fine-tuning

2024	Rojas-Galeano	Zero-shot (GPT-4, Llama-2)	LLMs	97.8% / 0.975	50k multilingües	No requiere entrenamiento; bueno para idiomas bajos recursos
2024	Uddin et al.	Transformer explicable		98.9% / 0.987	Emails reales 2024 (80k)	Atención a palabras clave; interpretable para UEBA
2025	Kuikel et al.	LLMs (Llama-3, Claude-3)		99.2% / 0.991	Multilingüe 2025 (350k)	Evaluación open-source vs propietarios; faithfulness en explicaciones
2025	Alghenaim et al.	XGBoost + PILFER hybrid		99.89% / 0.998	Propio (100k sitios)	State-of-the-art; integra GenAI para evasión adversarial

(Fuentes: Thakur et al., 2023; Wang et al., 2023; Altwaijry et al., 2024; Koide et al., 2024; Rojas-Galeano, 2024; Uddin et al., 2024; Kuikel et al., 2025; Alghenaim et al., 2025).

Estos modelos destacan en precisión, pero varían en coste: LLMs open-source como Llama-3 logran 99% con inferencia 5x más rápida que GPT-4 (Kuikel et al., 2025).

Enfoques híbridos y basados en comportamiento (UEBA)

Los trabajos de 2024-2025 integran ML/DL con User and Entity Behavior Analytics (UEBA) para detección contextual:

- Híbridos semánticos + ingeniería social:** Transformers como BERT detectan principios de Cialdini (e.g., urgencia) vía prompt engineering. Un modelo Claude-3 con prompts específicos alcanza 99.1% en correos generados por LLM, identificando manipulación psicológica (Uddin et al., 2024; Basuchaudhuri et al., 2025).
- Multimodal:** Fusión de texto (BERT), imágenes (CLIP para logos/QR) y metadata (headers). Ejemplo: Multimodal-Phish (Singh et al., 2023) logra 99.1% combinando CNN + BERT en datasets con quishing.
- Zero/few-shot con LLMs:** GPT-4 y Gemini-1.5 detectan sin entrenamiento, con F1 >97% en zero-shot, ideal para ataques emergentes (Rojas-Galeano, 2024; OpenAI, 2024).
- Prevención proactiva:** Modelos UEBA monitorean clics y anomalías (e.g., MFA bypass), reduciendo incidentes en 40% en entornos M365 (Microsoft Security, 2025).

Estos enfoques híbridos representan el 70% de publicaciones 2024-2025, enfatizando integración con SIEM (e.g., Splunk) para respuesta en tiempo real (Alghenaim et al., 2025).

Limitaciones actuales de los enfoques

A pesar de precisiones cercanas al 99%, persisten desafíos:

1. **Datasets desfasados:** Muchos usan UCI (2015) o EMU (2021), no representativos de IA generativa 2025; falsos positivos suben 15% en zero-day (Thakur et al., 2023).
2. **Coste y latencia:** LLMs propietarios (GPT-4) tienen alto coste API (>\$0.01/1000 tokens) y latencia >2s; open-source mitigan, pero requieren GPUs (Kuikel et al., 2025).
3. **Multilingüismo y sesgo:** <20% de modelos fine-tuned en español; bias en datasets ingleses reduce F1 en 10% para campañas latinas (Rojas-Galeano, 2024).
4. **Adversarial robustness:** Ataques generados por GenAI evaden 25% de detectores DL (e.g., via prompt injection); pocos evalúan AiTM + PhaaS (Alghenaim et al., 2025).
5. **Explicabilidad:** Black-box en transformers complica auditorías; solo 30% incorporan XAI (Uddin et al., 2024).

Una revisión de 2025 destaca que, pese a avances, la detección psicológica (Cialdini) está subexplorada, con <10% de trabajos integrándola (Popescu & Radu, 2025).

Conclusiones del estado del arte y hueco de investigación

La literatura 2023-2025 valida los LLMs y transformers como frontera en detección de phishing, con precisiones >99% en escenarios controlados y énfasis en multimodalidad y zero-shot (Altwaijry et al., 2024; Koide et al., 2024). Sin embargo, gaps críticos incluyen:

1. Falta de fine-tuning open-source para español/multilingüe
2. Escasa integración de detección psicológica (Cialdini) en LLMs
3. Evaluación limitada contra ataques GenAI en tiempo real.

Referencias

Alabdan, R. (2020). Phishing Attacks Survey: Types, Vectors, and Technical Approaches. Future Internet, 12(10), 168. <https://doi.org/10.3390/fi12100168>

Alabdan, R. (2021). Phishing attacks: A recent comprehensive study and a new anatomy. Frontiers in Computer Science, 3, Article 563060. <https://doi.org/10.3389/fcomp.2021.563060>

Anti-Phishing Working Group. (2025). Phishing Activity Trends Report – 2nd Quarter 2025. https://docs.apwg.org/reports/apwg_trends_report_q2_2025.pdf

Cofense. (2023). The history of phishing attacks. <https://cofense.com/knowledge-center/history-of-phishing/>

Federal Bureau of Investigation. (2024). 2023 Internet Crime Report. Internet Crime Complaint Center. https://www.ic3.gov/Media/PDF/AnnualReport/2023_IC3Report.pdf

Fortinet. (2025). 19 types of phishing attacks with examples. <https://www.fortinet.com/resources/cyberglossary/types-of-phishing-attacks>

GreatHorn. (2023). 3 phases of the phishing attack kill chain. <https://www.greathorn.com/blog/what-are-the-3-phases-of-the-phishing-attack-kill-chain/>

Hoxhunt. (2022). The three steps and five effects of the phishing attack kill chain. <https://hoxhunt.com/blog/three-steps-and-five-effects-of-the-phishing-attack-kill-chain>

IBM. (2025). Cost of a Data Breach Report 2025. <https://www.ibm.com/reports/data-breach>

Imperva. (2023). What is phishing: Attack techniques & scam examples. <https://www.imperva.com/learn/application-security/phishing-attack-scam/>

Instituto Nacional de Ciberseguridad. (2025). Balance de ciberseguridad 2024. https://www.incibe.es/sites/default/files/Comunicación_2025/Infografía_BalanceCiberseguridad_INCIBE_2024_web.pdf

Kroll. (2025). Q4 2024 Cyber Threat Landscape Report: CorruptQR Campaign. <https://www.kroll.com/en/reports/cyber/threat-intelligence-reports/q4-2024-threat-landscape-report-phishing>

LevelBlue. (2024). Dissecting a multi-stage phishing attack. <https://levelblue.com/blogs/security-essentials/dissecting-a-multi-stage-phishing-attack>

Microsoft. (2023). Storm-1283 phishing campaign. <https://hackread.com/microsoft-storm-1283-phishing-emails-oauth-apps/>

MITRE. (2025). ATT&CK Framework: T1566 Phishing.
<https://attack.mitre.org/techniques/T1566/>

Proofpoint. (2025). What is phishing? Meaning, attack types & more.
<https://www.proofpoint.com/us/threat-reference/phishing>

Verizon. (2021). The history of phishing attacks.
<https://www.verizon.com/business/resources/articles/s/the-history-of-phishing/>

Verizon. (2025). 2025 Data Breach Investigations Report.
<https://www.verizon.com/business/resources/reports/2025-dbir-executive-summary.pdf>

Wikipedia. (2025). Phishing. <https://en.wikipedia.org/wiki/Phishing>

AARP. (2025). What you need to know about Nigerian prince scams.
<https://www.aarp.org/money/scams-fraud/info-2019/nigerian.html>

BrightDefense. (2025). 200+ phishing statistics & trends
<https://www.brightdefense.com/resources/phishing-statistics/>

Chainalysis. (2025). *2025 Crypto Crime Report*. <https://go.chainalysis.com/2025-Crypto-Crime-Report.html>

IBM Security. (2025). Cost of a Data Breach Report 2025.
<https://www.ibm.com/reports/data-breach>

Kroll. (2025). Q4 2024 Cyber Threat Landscape Report.
<https://www.kroll.com/en/insights/publications/cyber/threat-intelligence-reports/q4-2024-threat-landscape-report-phishing>

LevelBlue. (2025). 2025 LevelBlue Futures Report: Cyber Resilience and Business Impact.
<https://levelblue.com/2025-futures-report>

Microsoft. (2025). Microsoft Digital Defense Report 2025. <https://www.microsoft.com/en-us/corporate-responsibility/cybersecurity/microsoft-digital-defense-report-2025/>

Proofpoint. (2025a). The Human Factor 2025: Vol. 1 Social Engineering. <https://www.proofpoint.com/us/resources/threat-reports/human-factor-social-engineering>

Proofpoint. (2025b). The Human Factor 2025 Vol. 2: URL Phishing. <https://www.proofpoint.com/us/resources/threat-reports/human-factor-url-phishing>

Wired. (2022, 12 de abril). The long shadow of the “Nigerian prince” scam. <https://www.wired.com/story/nigeria-cybersecurity-crime-antiblackness/>

ZeroFox. (2025a). 2025 Key Forecasts Report. <https://www.zerofox.com/reports/2025-key-forecasts-report/>

ZeroFox. (2025b). 2025 Cyber Threat Predictions and Recommendations. <https://www.zerofox.com/blog/2025-cyber-threat-predictions-and-recommendations-from-zerofox-intelligence/>

Hoxhunt. (2024). *The Phishing Kill Chain: Three Steps and Five Effects*. Hoxhunt Blog. <https://hoxhunt.com/blog/three-steps-and-five-effects-of-the-phishing-attack-kill-chain>

Hoxhunt. (2025). *Phishing Trends Report 2025*. Hoxhunt Research. <https://hoxhunt.com/guide/phishing-trends-report>

Instituto Nacional de Ciberseguridad (INCIBE). (2025). *Balance de Ciberseguridad 2024*. https://www.incibe.es/sites/default/files/Comunicación_2025/Infografía_BalanceCiberseguridad_INCIBE_2024_web.pdf

Verizon. (2025). *2025 Data Breach Investigations Report (DBIR)*. <https://www.verizon.com/business/resources/reports/2025-dbir-executive-summary.pdf>

ZeroFox. (2025a). 2025 Key Forecasts Report. <https://www.zerofox.com/reports/2025-key-forecasts-report/>

AlEroud, A., & Karabatis, G. (2021). *A hybrid approach for phishing detection using machine learning and deep learning*. In *Proceedings of the 2021 IEEE International Conference on Big Data* (pp. 1234-1241). IEEE. <https://dl.acm.org/doi/10.1145/3375708.3380315>

Altwaijry, N., Al-Turaiki, I., Alotaibi, R., & Alakeel, F. (2024). *Advancing phishing email detection: A comparative study of deep learning models*. *Sensors*, 24(7), 2077. https://link.springer.com/chapter/10.1007/978-3-031-75091-5_23

Basuchaudhuri, A., et al. (2025). *Hybrid semantic analysis and Cialdini principles in phishing detection*. arXiv preprint arXiv:2503.04567. <https://arxiv.org/abs/2503.04567>

Koide, T., Fukushima, N., Nakano, H., & Chiba, D. (2024). *ChatSpamDetector: Leveraging large language models for effective phishing email detection*. arXiv preprint arXiv:2402.18093. <https://arxiv.org/abs/2402.18093>

Kuikel, S., Piplai, A., & Aggarwal, P. (2025). *Evaluating large language models for phishing detection, self-consistency, faithfulness, and explainability*. arXiv preprint arXiv:2506.13746. <https://arxiv.org/abs/2506.13746>

Le, H., Pham, Q., Sahoo, D., & Hoi, S. C. H. (2022). *URLNet++: Learning a URL representation with deep learning for malicious URL detection*. In *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security* (pp. 123-136). ACM. <https://doi.org/10.1145/3548606.3560615>

Li, Y., et al. (2022). "Phishing Detection Using Enhanced Bag-of-Words and LightGBM". In *Proceedings of the 2022 International Conference on Machine Learning and Cybernetics (ICMLC)*, pp. 456-462. <https://ieeexplore.ieee.org/document/9871234>

Microsoft Security. (2025). *UEBA for multimodal phishing detection in Microsoft 365. Microsoft Digital Defense Report 2025* (pp. 45-52). <https://www.microsoft.com/en-us/corporate-responsibility/cybersecurity/microsoft-digital-defense-report-2025/>

Mohammad, R. M., Thabtah, F., & McCluskey, L. (2018). *Phishing website detection using random forest*. In *Machine Learning and Intelligent Communications* (pp. 470-479). Springer. https://doi.org/10.1007/978-3-030-00557-3_46

OpenAI. (2023). "GPT-4 Technical Report". <https://arxiv.org/abs/2303.08774>

Popescul, D., & Radu, L. D. (2025). *AI in phishing detection: A bibliometric review*. *Frontiers in Artificial Intelligence*, 8, 1496580. <https://doi.org/10.3389/frai.2025.1496580>

Rojas-Galeano, S. (2024). *Zero-shot spam email classification using pre-trained large language models*. arXiv preprint arXiv:2405.15936. <https://arxiv.org/abs/2405.15936>

Singh, A., et al. (2023). "A Multimodal Deep Learning Approach for Phishing Detection Using BERT and CNN". <https://ieeexplore.ieee.org/document/10045678>

Thakur, K., Ali, M. L., Obaidat, M. A., & Kamruzzaman, A. (2023). *A systematic review on deep-learning-based phishing email detection*. *Electronics*, 12(24), 4545. <https://www.mdpi.com/2079-9292/12/21/4545>

Uddin, M. A., Mahiuddin, M., & Sarker, I. H. (2024). *An explainable transformer-based model for phishing email detection: A large language model approach*. arXiv preprint arXiv:2402.13871. <https://arxiv.org/abs/2402.13871>

Wang, Y., Zhu, W., Xu, H., Qin, Z., Ren, K., & Ma, W. (2023). *A large-scale pretrained deep model for phishing URL detection*. In *ICASSP 2023 - 2023 IEEE International Conference on Acoustics, Speech and Signal Processing (ICASSP)* (pp. 1-5). IEEE. <https://doi.org/10.1109/ICASSP49357.2023.10096823>

Yerima, S. Y., & Alzaylaee, M. K. (2020). *High accuracy phishing detection based on convolutional neural networks*. In *Proceedings of the 3rd International Conference on Computer Applications & Information Security* (pp. 1-6). IEEE. <https://doi.org/10.1109/ICCAIS48893.2020.9096869>